

IMPORTANT

We've put the last chapter of this Fast Track on the Mindware DVD. Please read it from there. Write to editor@thinkdigit.com and tell us whether you prefer reading on screen or on paper. The way in which you get Fast Tracks in the future depends on this, so make sure to write in!

To prevent against a possible SQL injection attack (which could be as simple, or far more complex, than this example), the WordPress database class provides the `$wpdb->prepare()` method. This method, added in WordPress 2.3, uses the PHP `printf()` syntax (<http://php.net/printf>) for field replacement. It handles data sanitization of SQL statements to prevent against SQL injection. Note that, like `printf()`, placeholders can use an “order” index.

Instead of using `%d` to indicate a numerical replacement, you could use the `%1$d` syntax to indicate, “replace this placeholder with the first replacement value in the format of a number.”

The two placeholders the `prepare()` method supports are `%d` for integers and `%s` for strings. Note that in neither case do you quote the placeholder. WordPress will take care of proper quoting for you. 